



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI•

Technische Richtlinie TR-03171

Optisch verifizierbarer kryptographischer Schutz von Verwaltungsdokumenten
(Digitale Siegel)

Version 0.9



Änderungshistorie

Tabelle 1: Versionierung

Version	Datum	Name	Beschreibung
0.7	25.05.2021	BSI	Erstveröffentlichung
0.8	21.05.2024	BSI	Ergänzung des Statusservers; Anpassung der Profil- und Zertifikatsreferenz mittels UUID; Aktualisierung der Datentypen
0.9	01.06.2026	BSI	Anpassung der Zertifikatsreferenz, Erweiterung XML-Schema, Rückrufmechanismus

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: digitale-siegel@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2024

Inhalt

1	Einleitung.....	4
2	Organisatorische und technische Grundlagen.....	5
2.1	Profilverwaltung.....	5
2.2	Zertifikatsverwaltung.....	5
2.3	Rückrufmechanismus.....	6
2.4	REST-Schnittstelle für den Profil- und Zertifikatsabruf.....	6
2.4.1	Abfrage einzelner Profile und Zertifikate.....	6
2.4.2	Abfrage einer Profil- oder Zertifikatsliste.....	7
2.4.3	Rückgabewerte und Absicherung der REST-Schnittstelle.....	8
2.5	Validierung der optischen Siegel.....	8
3	Format digitaler Siegel auf Verwaltungsdokumenten.....	9
3.1	Header.....	9
3.2	Message Zone.....	10
3.3	Verwendete Zertifikate.....	12
4	Dokumentenprofile.....	13
5	Anforderungen an den Prozess der Siegelprüfung.....	17
6	Rückrufmechanismus.....	19
	Literaturverzeichnis.....	23

1 Einleitung

Zahlreiche Verwaltungsprozesse in Deutschland resultieren in der Erstellung von Bescheiden, Zertifikaten oder sonstigen Dokumenten. Damit solche Dokumente als Nachweis gegenüber Dritten verwendet werden können, wurden sie traditionell mit Dienstsiegeln und/oder Unterschriften der Bearbeitenden versehen. Die handschriftliche Unterschrift kann in vielen Bereichen schon seit langem durch eine qualifizierte elektronische Signatur ersetzt werden. Die mit der eIDAS-Verordnung (eIDAS-VO) EU-weit eingeführten qualifizierten Siegel bieten einen äquivalenten kryptografischen Mechanismus für die Siegelung von Daten durch eine juristische Person. Die Siegel stellen einen elektronischen Herkunftsnachweis dar und verfügen über dieselben mathematischen Eigenschaften.

Mit fortgeschrittenen oder qualifizierten elektronischen Signaturen oder Siegeln lässt sich die Authentizität und Integrität von Dokumenten jederzeit überprüfen, solange sie in der ursprünglichen Form elektronisch vorliegen. Sofern die Dokumente jedoch nur in Papierform vorliegen oder z. B. auf einem mobilen Endgerät präsentiert werden, sind diese Integritätssicherungen nicht mehr prüfbar. Hierfür wurden optisch verifizierbare digitale Siegel entwickelt, die die wesentlichen Daten eines Nachweises in strukturierter Form und kryptographisch gesichert enthalten und aufgrund der kompakten binären Repräsentation eine Abbildung als Barcode (z.B. Datamatrixcode, QR-Code) gestatten. Durch das Erzeugen eines digitalen Siegels (in Form eines 2D-Barcodes) wird durch eine kryptographische Signatur, die Integrität und Authentizität der im Barcode gespeicherten Daten sichergestellt. Sofern bei der Erstellung ein entsprechendes Zertifikat verwendet wurde, handelt es sich bei dem geschützten Datensatz um ein mit einer qualifizierten elektronischen Signatur bzw. einem qualifizierten elektronischen Siegel versehenes Dokument.

Auf diese Weise lässt sich die Authentizität und Integrität der Inhalte eines Verwaltungsdokuments feststellen, etwa im Rahmen der Prüfung einer Genehmigung durch Mitarbeitende einer Ordnungsbehörde, ohne dass dazu ein Zugriff auf in einem Hintergrundsystem gespeicherte Informationen zum Vorgang notwendig wäre. Ausgenommen sind davon beispielsweise aktuelle Sperrinformationen des Zertifikateausstellers. Als Proof-of-Concept (PoC) ist in Kapitel 6 eine Rückrufmöglichkeit vorgestellt, wie bereits ausgestellte Nachweise trotz gültiger Signatur zurückgerufen werden können.

Das vorliegende Dokument beschreibt einen auf (TR-03137-1) basierenden Standard zur Erzeugung digitaler Siegel auf Verwaltungsdokumenten.

2 Organisatorische und technische Grundlagen

Sofern eine Stelle lediglich Nachweise prüfen möchte, die sie selbst erstellt und signiert hat, kann sie die dafür erforderlichen Formate und Konventionen selbst festlegen. Soll es jedoch ermöglicht werden, dass ein Verwaltungsdokument von unterschiedlichen Stellen (z. B. anderen Kommunen) validiert wird, so ist die Einhaltung einheitlicher Konventionen erforderlich. Zudem benötigt die prüfende Stelle Zugriff auf die Dokumentformate (Dokumentenprofile im Sinne der (TR-03137-1)) sowie auf die zur Erstellung der elektronischen Signatur / des elektronischen Siegels verwendeten Zertifikate samt zugehöriger Zertifikatskette und Rückrufinformationen.

2.1 Profilverwaltung

Damit eine Anwendung die Inhalte aller Verwaltungsdokumente strukturiert anzeigen kann, die von einer öffentlichen Stelle ausgegeben und mit einem optisch verifizierbaren digitalen Siegel versehen wurden, ist es notwendig, dass sie Zugriff auf alle zugrundeliegenden Dokumentenprofile hat. Jede Verwaltungsstelle oder eine von ihr beauftragte Stelle, die optisch verifizierbare Siegel ausstellt, muss die verwendeten Profile Dritten kostenlos und öffentlich zugänglich zur Verfügung stellen. Damit ist eine föderale Nutzung und Weiterverwendung möglich und bietet Dritten die Möglichkeit, Siegel und die zugrundeliegenden Profile zu validieren. Die benötigten Profile können dann bei Bedarf online abgerufen oder durch entsprechende Anwendungen bereits im Vorfeld für Offline-Prüfungen heruntergeladen werden. (Vgl. Kapitel 3.2, Tabelle 9)

2.2 Zertifikatsverwaltung

Während fortgeschrittene und qualifizierte Signaturen und Siegel meistens das Zertifikat enthalten, mit dem sie erstellt wurden, enthalten optisch verifizierbare digitale Siegel aufgrund der begrenzten Speicherkapazität des Barcodes nur eine Referenz auf ein Zertifikat, das an anderer Stelle vorliegt. Damit eine Anwendung die Integrität aller Verwaltungsdokumente prüfen kann, die von einer öffentlichen Stelle ausgegeben und mit einem digitalen Siegel versehen wurden, ist es notwendig, dass sie Zugriff auf alle verwendeten Zertifikate (und deren Zertifikatskette) hat. Hierzu stellt die Verwaltungsstelle oder eine von ihr beauftragte Stelle ihr Zertifikat, zusammen mit jeweils einer eindeutigen Kennung bestehend aus *Signer Identifier* („DEZV“) und *Certificate Reference* (<SHASUM>), öffentlich zugänglich zur Verfügung. Dabei lautet der *Signer Identifier* stets „DEZV“. Die *Certificate Reference* entspricht dem SHA1-Hashwert über das gesamte Signatur-Zertifikat (in seiner originalen DER-Kodierung). Für die C40-Kodierung des Hashwertes wird dessen hexadezimale Darstellung mit Großbuchstaben verwendet. Die Gesamtlänge der *Signer* und *Certificate Reference* beträgt 32 Byte nach C40-Kodierung (DOC9303-13). Die exakte Kodierung kann der Tabelle 5 entnommen werden.

Die benötigten Zertifikate und Zertifikatsketten können dann bei Bedarf online geprüft oder durch entsprechende Anwendungen bereits im Vorfeld für Offline-Prüfungen heruntergeladen werden. Für die Offline-Nutzung ist es notwendig, dass das Zertifikat zusammen mit der dazugehörigen *Certificate Reference* gespeichert wird. Dabei ist zu beachten, dass Zertifikate bei Offline-Verwendung gerade nicht in Echtzeit auf Gültigkeit bzw. Rückruf geprüft werden können und eine solche Prüfung daher je nach Anwendungsszenario mit den für eine Offline-Prüfung heruntergeladenen Zertifikaten regelmäßig online durchzuführen ist.

Es muss ein geeigneter Authentifizierungsmechanismus implementiert werden, damit die Zertifikatsverwaltung ausschließlich Zertifikate von autorisierten und berechtigten Stellen akzeptiert und

verarbeitet. In der Prüfanwendung muss als Vertrauensanker mindestens die EU Trusted Lists (EU-LOTL¹) und die Verwaltungs-PKI² integriert sein.

2.3 Rückrufmechanismus

Der hier dargestellte Mechanismus in Kapitel 6 dient lediglich als möglicher Lösungsvorschlag und kann als fachlicher Rückrufmechanismus unabhängig von der Signatur verwendet werden. Der Rückrufmechanismus funktioniert nur unter der Prämisse, dass das verwendete Siegel- bzw. Signaturzertifikat noch nicht abgelaufen oder gesperrt ist (rückrufbare Siegel sollten daher grundsätzlich nur als gültig angezeigt werden, wenn das verwendete Zertifikat noch gültig ist). Für die Umsetzung des Mechanismus ist die Bereitstellung eines öffentlich zugänglichen Servers für den Abruf der Rückrufinformationen notwendig und muss durch die ausgebende Verwaltungsstelle oder in deren Auftrag kostenlos Dritten zur Verfügung gestellt werden.

2.4 REST-Schnittstelle für den Profil- und Zertifikatsabruf

Eine REST-Schnittstelle muss für den Bezug der Profile und Zertifikate bereitgestellt werden. Die jeweilige Kodierung der Bezugspunkte können der Tabelle 9 bzw. der Tabelle 10 in Kapitel 3.2 entnommen werden.

2.4.1 Abfrage einzelner Profile und Zertifikate

Sofern ein spezifisches Zertifikat oder Profil abgerufen werden soll, werden die UUID des Profils bzw. die SHASUM des Zertifikats als Variable „profilenumber“ bzw. „cert“ bei der Anfrage übergeben:

Tabelle 2: Profilabruf als Beispiel

Abruf	Beispiel
Abruf der hinterlegten Profile:	GET /profiles HTTP/1.1 Accept: application/xml
Abruf eines Profils:	GET /profiles?profilenumber=3ed0377e244711f1ba067f0493d1c349 HTTP/1.1 Accept: application/xml

Tabelle 3: Zertifikatsabruf als Beispiel

Abruf	Beispiel
Abruf der hinterlegten Zertifikate:	GET /certificates HTTP/1.1 Accept: application/xml
Abruf eines Zertifikats:	GET /certificates?cert=7f043c5b99d7c8057efd672ecda8091115221925 HTTP/1.1 Accept: application/txt

¹ <https://ec.europa.eu/tools/lotl/eu-lotl.xml>

² https://www.bsi.bund.de/DE/Themen/Oeffentliche-Verwaltung/Moderner-Staat/Verwaltungs-PKI/Wurzelzertifizierungsstelle/FingerprintsderWurzelzertifikate/fingerprintsderwurzelzertifikate_node.html

2.4.2 Abfrage einer Profil- oder Zertifikatsliste

Sofern die UUID bzw. das Zertifikat nicht bekannt ist, kann eine jeweilige Liste bei dem Bezugspunkt abgerufen werden. Die Profilliste muss wie nachfolgend im XML-Format aufgebaut sein. In jedem Tag „profile“ muss mindestens das Attribut „profileNumber“ vorhanden sein, die weiteren Attribute können zur Beschreibung enthalten sein und orientieren sich an der Profildefinition aus Kapitel 4. Analog gilt diese Vorgabe für die Zertifikatsliste, bei der zu jedem Tag „cert“ mindestens das Attribut „shasum“ vorhanden sein muss:

Tabelle 4: Beispiele für die Rückgabewerte der Profil- bzw. Zertifikatsliste

Typ	Beispiel für Rückgabewerte
Profile	<pre> <?xml version="1.0" encoding="UTF-8"?> <profileList> <profile> <profileNumber>3ed0377e244711f1ba067f0493d1c349</profileNumber> <profileName>Parkausweis</profileName> <creator>Ordnungsamt Stadt Bonn</creator> <category>Verkehr und Parken</category> <leikaID>99115005104000</leikaID> <leikaID>99115005104001</leikaID> </profile> <profile> <profileNumber>1ed0311e244711f1ba067f0493d1c349</profileNumber> <profileName>Meldebestaetigung</profileName> <creator>Stadt Bonn</creator> <category>Einwohnermeldung</category> <leikaID>99115003012000</leikaID> </profile> </profileList> </pre>
Zertifikate	<pre> <?xml version="1.0" encoding="UTF-8"?> <certList> <cert> <shasum>7f043c5b99d7c8057efd672ecda8091115221925</shasum> <certOwner>Stadt Bonn</certOwner> <certIssuer>BSI</certIssuer> </cert> <cert> <shasum>7f043c5b99d7c8057efd672ecda8091115247924</shasum> <certOwner>Stadt Berlin</certOwner> <certIssuer>BSI</certIssuer> </cert> </certList> </pre>

2.4.3 Rückgabewerte und Absicherung der REST-Schnittstelle

Als Rückgabe der REST-Schnittstelle wird

- für die Profilliste mit allen hinterlegten UUIDs das XML-Dokument in UTF8-kodiert,
- für Profile das XML-Dokument als UTF8 kodiert,
- für die Zertifikatsliste mit allen hinterlegten Zertifikaten das XML-Dokument in UTF8-kodiert und
- für Zertifikate das x509-Dokument in PEM-Kodierung

erwartet.

Fehlerhafte Anfragen sollten mittels http response status codes beantwortet werden.

Die REST-Schnittstelle (Bezugspunkte) muss nach dem Stand der Technik (IT-Grundschutz, ISO 27001) abgesichert werden. Dazu muss die Übertragung des Profils und des Zertifikats über eine serverseitige TLS-Transportverschlüsselung erfolgen. Die Bereitstellung der Profile, Zertifikate und REST-Schnittstelle kann im Auftrag der Verwaltungsstelle durch Dritte erfolgen.

2.5 Validierung der optischen Siegel

Mit dem Aufbringen der optischen Siegel auf Verwaltungsdokumenten müssen vorab Festlegungen durch die siegelnde Stelle getroffen werden. Im Kapitel 5 wird beschrieben, wie ein Validierungsprozess mittels einer App durchgeführt werden kann. In der vorliegenden Technischen Richtlinie wird zur Validierung des Siegels das Schalenmodell festgelegt. Das bedeutet, dass zum Zeitpunkt der Validierung des Siegels das Zertifikat, mit welchem das optische Siegel aufgebracht wurde, gültig sein muss. Das zugrundeliegende papierbasierte Dokument ist ggf. unbeschränkt oder länger gültig als das elektronische Zertifikat. Es kann sinnvoll sein, auf diesen Umstand auf dem zugrundliegenden Verwaltungsdokument hinzuweisen oder in den entsprechenden Verwaltungsprozessen zu berücksichtigen.

3 Format digitaler Siegel auf Verwaltungsdokumenten

Das Format digitaler Siegel auf Verwaltungsdokumenten folgt grundsätzlich den Vorgaben der (TR-03137-1). Zulässige Ausprägungen sowie notwendige Abweichungen werden im Folgenden beschrieben.

3.1 Header

Die vorliegende Technische Richtlinie unterstützt ausschließlich Header der Version 4 gemäß (TR-03137-1). Der Header ist gemäß (TR-03137-1) zu befüllen. Der Aufbau wird im Folgenden erläutert sowie vorgeschriebene Belegungen angegeben.

Als Dokumentenkategorie wird die Nummer 201 (0xC9) für Verwaltungsdokumente vergeben, die auf Grundlage dieser technischen Richtlinie erstellt wurden. (Die Nummer 200 (0xC8) wurde in der Vergangenheit für Verwaltungsdokumente vergeben, die mit den vorherigen Versionen der TR erstellt wurden.) Aufgrund der zu erwartenden Vielzahl an zu siegelnden Verwaltungsdokumenten wird die jeweilige Ausprägung des Verwaltungsdokuments nicht im für Ausprägungen vorgesehenen Header-Feld *Document Feature Definition Reference*, der nur 256 verschiedene Werte zulässt, sondern in einem eigenen Feld als Dokumentenprofilnummer in der Message Zone (s. Abschnitt 3.2) codiert.

Tabelle 5: Header gemäß TR-03137-1

<i>Position gem. (TR-03137-1)</i>	<i>Länge (Byte)</i>	<i>Inhalt</i>	<i>Wert</i>
0x00	1	<i>Magic Constant</i>	0xDC
0x01	1	<i>Version</i>	0x03
0x02	2	<i>Issuing Country</i>	„D<<“ in C40 kodiert. (0x6abc)
0x04	32	<i>Signer Identifier and Certificate Reference</i>	Konkatenation aus den folgenden Werten, die in C40 kodiert werden: „DEZV40“+“SHA1 (Zertifikat)“ (Die ersten 4 Zeichen repräsentieren den Signer Identifier, gefolgt von 2 Zeichen, die die Länge der darauf nachfolgenden SHA1-Summe angeben.)
0x24	3	<i>Document Issue Date</i>	Ausgabedatum (MMDDYYYY) des Dokuments ³ .
0x27	3	<i>Signature Creation Date</i>	Erstellungsdatum (MMDDYYYY) der Signatur. ^{3,4}
0x28	1	<i>Document Feature Definition Reference</i>	0x01 für Konformität mit Abschnitt 3.2 (die eigentliche Feature Definition der Inhaltsdaten wird im ersten Feld der Message Zone gesetzt)
0x29	1	<i>Document Type Category</i>	0xC9 (für Profile nach TR-03171 Version 0.8: 0xC8)

In der Summe ergibt sich eine Headergröße von 44 Byte.

³ Die Kodierung der Datumsangaben erfolgt nach der Spezifikation (DOC9303-13).

⁴ Sollte für die Signaturprüfung eine Uhrzeit angenommen werden müssen, ist von 00:00:00 Uhr des jeweiligen Signaturtages auszugehen.

3.2 Message Zone

Die Message Zone ist wie in (TR-03137-1) definiert zu befüllen. Dabei ist unter dem Tag 0x00 die Dokumentenprofilnummer zu hinterlegen. Die Tags 0x01 und 0x02 bieten die Möglichkeit, optional zwei Datumsangaben zu hinterlegen. Der Tag 0x01 „validFrom“ gibt an, ab wann das Dokument gültig ist. Der Tag 0x02 „validTo“ gibt an, bis wann das Dokument gültig ist. Die obligatorischen Tags 0x03 und 0x04 beinhalten die URI-Bezugspunkte, in denen das verwendete Profil und verwendete Zertifikat hinterlegt sind. Die Tags 0x05 und 0x06 sind für Rückrufmechanismen vorgesehen. Der Tag 0x05 beschreibt bei dem Verwenden der *Bitstring Status List* (W3C, 2025) den URI-Bezugspunkt beziehungsweise die Rückrufinformation. Der Tag 0x06 gibt den Indexeintrag in der Rückrufliste an. Für Inhaltsdaten stehen die Tags von 0x0A bis 0xFE zur Verfügung.

Beispielsweise hat der Datamatrix-Barcode eine maximale Kapazität von 1.555 Byte. Ausgehend von dem in diesem Dokument angeführten Beispiel für die Bezugspunkte des Profils und Zertifikats, werden mit allen obligatorischen Tags aus dem Header und der Message Zone insgesamt 178 Byte belegt, inklusive der Signaturzone. Somit stehen in der Message Zone noch 1.377 Byte zur freien Verfügung. Der weitere Aufbau der Message Zone mit obligatorischen und fakultativen Tags ist in Kapitel 4 beschrieben.

Tabelle 6: Angabe der Dokumentenprofilnummer in der Message Zone

Eigenschaft	Wert
tag	„0x00“
length	Die Länge des nachfolgenden Werts, in diesem Fall einer UUID, beträgt 16 Bytes (128 Bit) und wird hexadezimal als „0x10“ dargestellt.
value	Dokumentenprofilnummer, die als 128 Bit lange UUID im ASN.1 OCTET STRING-Format kodiert wird.

Tabelle 7: Angabe der optionalen Datumsangabe „validFrom“ in der Message Zone

Eigenschaft	Wert
tag	„0x01“
length	Die Länge des nachfolgenden Wertes, repräsentiert die Länge der Datumsangabe „validFrom“, feste Länge von 8 Byte.
value	Eine Zeichenfolge, die die Datumsangabe „validFrom“ enthält. Die Datumsangabe ist im ASN.1 DATE-Format als YYYYMMDD kodiert. Beispiel: Der Wert „20250101“ wird als „0x3230323530313031“ kodiert.

Tabelle 8: Angabe der optionalen Datumsangabe „validTo“ in der Message Zone

Eigenschaft	Wert
tag	„0x02“
length	Die Länge des nachfolgenden Wertes, repräsentiert die Länge der Datumsangabe „validTo“, feste Länge von 8 Byte.
value	Eine Zeichenfolge, die die Datumsangabe „validTo“ enthält. Die Datumsangabe ist im ASN.1 DATE-Format als YYYYMMDD kodiert.

Tabelle 9: Angabe der Profilbezugs-URI „profileURI“ in der Message Zone

Eigenschaft	Wert
tag	„0x03“
length	Die Länge des nachfolgenden Wertes, welcher den Bezugspunkt des Profils beschreibt. In dem vorliegenden Beispiel wäre das „0x14“.
value	Eine Zeichenfolge, die den URI-Bezugspunkt für die Dokumentenprofile bereitstellt. Die URI ist in der Form „example.com/profiles“ im ASN.1 UTF8String-Format kodiert. Das Beispiel „example.com/profiles“ wird codiert in: <pre>65 78 61 6D 70 6C 65 2E 63 6F 6D 2F 70 72 6F 66 69 6C 65 73</pre> Anhand der UUID des Profils kann die hinterlegte Datei in der URI identifiziert werden. Das Protokoll („https://“) wird nicht mit kodiert und muss durch die Prüf-App wieder hinzugefügt werden.

Tabelle 10: Angabe der Zertifikatsbezugs-URI „certificateURI“ in der Message Zone

Eigenschaft	Wert
tag	„0x04“
length	Die Länge des nachfolgenden Wertes, welcher den Bezugspunkt des Zertifikats beschreibt. In dem vorliegenden Beispiel wäre das „0x18“.
value	Eine Zeichenfolge, die den URI-Bezugspunkt für die Zertifikate bereitstellt. Die URI ist in der Form „example.com/certificates“ im ASN.1 UTF8String-Format kodiert. Das Beispiel „example.com/certificates“ wird codiert in: <pre>65 78 61 6D 70 6C 65 2E 63 6F 6D 2F 63 65 72 74 69 66 69 63 61 74 65 73</pre> Anhand des Hashwertes des Zertifikats kann die hinterlegte Datei in der URI identifiziert werden. Das Protokoll („https://“) wird nicht mit kodiert und muss durch die Prüf-App wieder hinzugefügt werden.

Tabelle 11: Angabe der optionalen Statusserver-URI „statusURI“ in der Message Zone

Eigenschaft	Wert
tag	„0x05“
length	Die Länge des nachfolgenden Wertes, welcher den Bezugspunkt des Status beschreibt. In dem vorliegenden Beispiel wäre das „0x12“.
value	Eine Zeichenfolge, die den URI-Bezugspunkt für die Status bereitstellt. Die URI ist in der Form „example.com/status“ im ASN.1 UTF8String-Format kodiert. Das Beispiel „example.com/status“ wird codiert in: <pre>65 78 61 6D 70 6C 65 2E 63 6F 6D 2F 73 74 61 74 75 73</pre> Das Protokoll („https://“) wird nicht mit kodiert und muss durch die Prüf-App wieder hinzugefügt werden.

Tabelle 12: Angabe des optionalen Statuslistenindex „*statusListIndex*“ in der Message Zone

Eigenschaft	Wert
tag	„0x06“
length	Die Länge des nachfolgenden Wertes, welcher den Index in der <i>Bitstring Status List</i> beschreibt. In dem vorliegenden Beispiel wäre das „0x03“.
value	Eine Zeichenfolge, die den Statuslistenindex für die Status bereitstellt. Der Index ist im ASN.1 INTEGER-Format kodiert. Dieses optionale Feld wird neben der Statusserver-URI („<i>statusURI</i>“) benötigt, wenn das Konzept der <i>Bitstring Status List</i> realisiert wird. Der Wert gibt den Index innerhalb der Statusliste an, welche den Status von verschiedenen Dokumenten abbildet. Der Index ist dem Verwaltungsdokument somit eindeutig zugeordnet. Beispiel: Der Wert „424242“ wird als „0x067932“ kodiert.

3.3 Verwendete Zertifikate

Für die Erstellung fortgeschrittener oder qualifizierter Signaturen oder Siegel können verschiedenartige Zertifikate zum Einsatz kommen:

- Fortgeschrittene Signaturen und Siegel können beispielsweise mit Zertifikaten aus der Verwaltungs-PKI erzeugt werden.
- Zur Erstellung qualifizierter Signaturen und Siegel werden qualifizierte Zertifikate eines kommerziellen qualifizierten Vertrauensdiensteanbieters benötigt.

Um keine zusätzlichen Einschränkungen an die zu verwendenden Zertifikate zu machen, gelten im Anwendungsbereich der vorliegenden Technischen Richtlinie die Vorgaben aus Abschnitt 2.2.1 des (DOC9303-13) nicht. Bei Verifizierung eines digitalen Siegels wird das benötigte Zertifikat nicht über die darin enthaltenen Zertifikatsdetails, sondern ausschließlich über den SHA1 Hashwert identifiziert.

4 Dokumentenprofile

Zur korrekten Codierung und Darstellung der Daten im digitalen Siegel ist ein Profil wie nachfolgend aufgebaut. Es enthält zudem Metadaten, die zusätzliche und notwendige Informationen beschreiben. Die Metadaten des Profils werden nicht im digitalen Siegel codiert.

Die Metadaten des Profils sind nachfolgend beschrieben:

- Dokumentenprofilnummer („`profileNumber`“) [obligatorisch]

Zur eindeutigen Identifizierung jedes Profils wird eine 128-Bit lange UUID (Universally Unique Identifier) der Version 4 verwendet, die gemäß (RFC4122) mit echten Zufalls- oder Pseudo-Zufallszahlen erstellt wird. Diese UUID ermöglicht eine dezentrale und einzigartige Kennzeichnung jedes Profils und kann von der erstellenden Stelle direkt generiert werden, ohne dass ein zentraler Erstellungsprozess notwendig ist. Nach der Erzeugung dient die UUID fortan als dauerhafte und unverwechselbare Identifikationsnummer für das jeweilige Profil. Sollte es eine Änderung an einem Profil geben, so bekommt dieses eine neue Dokumentenprofilnummer. Für die Speicherung und Übertragung der 128 Bit langen UUID muss der ASN.1 „OCTET STRING-Typ“ (wie unter Tag 0x00 der Message Zone beschrieben) genutzt werden. In textueller Repräsentation kann hingegen auf die Formatierung mit Bindestrichen in fünf Gruppen zurückgegriffen werden, zur Erhöhung der Lesbarkeit. Die Dokumentenprofilnummer findet sich somit sowohl in den Metadaten des Profils als auch unter Tag 0x00 der Message Zone.

- Versionsnummer der Technischen Richtlinie („`versionTR`“) [obligatorisch]

Mit der Versionsnummer der TR wird sichergestellt, dass trotz einem eventuell abweichenden Aufbau der Message Zone in zukünftigen Versionen, die Daten korrekt interpretiert werden können.

- Profilname („`profileName`“) [fakultativ]

Der Profilname ist ein frei wählbarer, beschreibender Name, der das Profil für Menschen leicht identifizierbar macht. Er dient der schnellen Orientierung und Unterscheidung in der Praxis und sollte daher klar und aussagekräftig sein.

- Ersteller des Profils, zuständige Stelle („`creator`“) [fakultativ]

Bezeichnet die Organisationseinheit oder Behörde, die für die Verwendung und Verwaltung des Profils zuständig ist. Dies umfasst die Verantwortung für die Pflege, Aktualisierung und Anwendung des Profils im Rahmen ihrer spezifischen administrativen und operativen Tätigkeiten. Die Angabe dieser Stelle stellt sicher, dass für jedes Profil klar ist, welche Einrichtung als Ansprechpartner für Rückfragen oder für die Klärung von Sachverhalten bezüglich des Profils dient.

- Kategorie des Profils („`category`“) [fakultativ]

Dieses Feld erlaubt eine freie Texteingabe zur weiteren Klassifizierung des Profils. Es kann zur Gruppierung oder thematischen Einordnung des Profils innerhalb der Verwaltung genutzt werden.

- Schlüssel der relevanten Verwaltungsleistung, LeiKa-ID⁵ („`leikaID`“) [fakultativ]

Dieser Schlüssel dient zur Zuordnung des Profils zu spezifischen Verwaltungsleistungen. Wenn genutzt, werden die LeiKa-IDs als Identifikatoren für die jeweiligen Verwaltungsleistungen verwendet. Es können mehrere LeiKa-IDs angegeben werden, um das Profil mit verschiedenen Verwaltungsleistungen zu verknüpfen. Zur Trennung der LeiKa-IDs wird ein Semikolon (;) als standardisiertes Trennzeichen eingesetzt.

- Präsenz Beginndatum („`validFromPresent`“) [obligatorisch]

Dieses Feld zeigt an, ob die Angabe des Beginns des Gültigkeitszeitraums des gesiegelten Dokuments (Beginndatum) in der Message Zone des Siegels (Tag: 0x01) enthalten sein soll. Folgende Optionen stehen zur Verfügung:

- `true`: Das Beginndatum muss immer präsent sein
- `false`: Das Beginndatum darf nicht präsent sein
- Präsenz Ablaufdatum („validToPresent“) [obligatorisch]

Dieses Feld zeigt an, ob die Angabe des Endes des Gültigkeitszeitraums des gesiegelten Dokuments (Ablaufdatum) in der Message Zone des Siegels (Tag: 0x02) enthalten sein soll. Folgende Optionen stehen zur Verfügung:

- `true`: Das Ablaufdatum muss immer präsent sein
- `false`: Das Ablaufdatum darf nicht präsent sein

Der Aufbau der frei wählbaren Attribute, welche zur korrekten Codierung und Darstellung der Daten im digitalen Siegel notwendig sind, ist nachfolgend beschrieben (beginnend mit Tag 0x0A. Die Tags 0x07 bis 0x09 sind für spätere Verwendung reserviert). Es werden nur Datenfelder nach den in Abschnitt 3.2 genannten Feldern beschrieben. Es sind daher nur Tags von 10 bis 254 (0x0A bis 0xFE) zu verwenden:

Liste der enthaltenen Datenfelder (TLV-Objekte) mit folgenden Angaben:

- Tag (Position)
- Angabe, ob das Datenfeld optional ist
- Name des Datenfeldes
- Beschreibungstext
- maximale Länge (zu ignorieren bei den Datentypen `BOOLEAN`, `INTEGER`, `DATE`, `DATE-TIME`)
- Datentyp

Folgende Standard ASN.1 Datentypen (X.680) stehen zur Verfügung:

- `BOOLEAN`
- `INTEGER`
- `OCTET STRING`
- `UTF8String`
- `DATE`
- `DATE-TIME`

Das Profil ist in Form eines XML-Datensatzes gemäß nachfolgendem Schema zu erstellen.

```

<?xml version="1.0" encoding="UTF-8"?>
<xs:schema xmlns:xs="http://www.w3.org/2001/XMLSchema"
elementFormDefault="qualified">

    <!-- Definiert ASN.1-basierte Standarddatentypen für die Attribute jedes
'entry'-Elements -->
    <xs:simpleType name="typeType">
        <xs:restriction base="xs:string">
            <xs:enumeration value="BOOLEAN" />
            <xs:enumeration value="INTEGER" />
            <xs:enumeration value="OCTET_STRING" />
            <xs:enumeration value="UTF8String" />
            <xs:enumeration value="DATE" />
            <xs:enumeration value="DATE-TIME" />
        </xs:restriction>
    </xs:simpleType>

    <!-- Definiert einen Typ für UUIDv4 ohne Bindestriche, ausschließlich in
Großbuchstaben -->
    <xs:simpleType name="UUIDv4Type">
        <xs:restriction base="xs:string">
            <xs:pattern value="[0-9A-F]{32}" />
        </xs:restriction>
    </xs:simpleType>

    <!-- Definiert einen Typ für Tags, beschränkt auf Werte von 10 bis 254 -->
    <xs:simpleType name="tagType">
        <xs:restriction base="xs:integer">
            <xs:minInclusive value="10" />
            <xs:maxInclusive value="254" />
        </xs:restriction>
    </xs:simpleType>

    <!-- Definiert eine leikaID, welche eine oder mehrere 14-stellige numerische
Identifikationsnummern beschreibt, getrennt durch Semikola. -->
    <xs:simpleType name="LeikaIDType">
        <xs:restriction base="xs:string">
            <xs:pattern value="\d{14} (; \d{14}) *" />
        </xs:restriction>
    </xs:simpleType>

    <!-- Definiert den komplexen Typ für Einträge, der verschiedene Felder
umfasst -->
    <xs:complexType name="entryType">
        <xs:sequence>
            <xs:element name="name" type="xs:string" />
            <xs:element name="description" type="xs:string" />
            <xs:element name="length" type="xs:positiveInteger" minOccurs="0" />
            <xs:element name="type" type="typeType" />
            <xs:element name="defaultValue" type="xs:string" minOccurs="0" />
        </xs:sequence>
        <xs:attribute name="tag" type="tagType" use="required" />
        <xs:attribute name="optional" type="xs:boolean" />
    </xs:complexType>

```

```
<!-- Definiert das Hauptelement 'profile', das die Datenstruktur für Profile
festlegt, die zur Erstellung optischer Siegel verwendet werden -->
<xs:element name="profile">
  <xs:complexType>
    <xs:sequence>
      <xs:element name="profileNumber" type="UUIDv4Type"/>
      <xs:element name="versionTR" type="xs:string"/>
      <xs:element name="profileName" type="xs:string" minOccurs="0"/>
      <xs:element name="creator" type="xs:string" minOccurs="0"/>
      <xs:element name="category" type="xs:string" minOccurs="0"/>
      <xs:element name="leikaID" type="LeikaIDType" minOccurs="0"/>
      <xs:element name="validFromPresent" type="xs:boolean"
minOccurs="1"/>
      <xs:element name="validToPresent" type="xs:boolean"
minOccurs="1"/>
      <xs:element name="entry" type="entryType" maxOccurs="245"/>
    </xs:sequence>
  </xs:complexType>
  <xs:unique name="tagNo">
    <xs:selector xpath="entry"/>
    <xs:field xpath="@tag"/>
  </xs:unique>
</xs:element>
</xs:schema>
```


5 Anforderungen an den Prozess der Siegelprüfung

Die Prüfung des optischen Siegels ist mittels einer App durchzuführen. Der Ablauf der Validierung ist in dem nachfolgenden Ablaufmodell dargestellt:

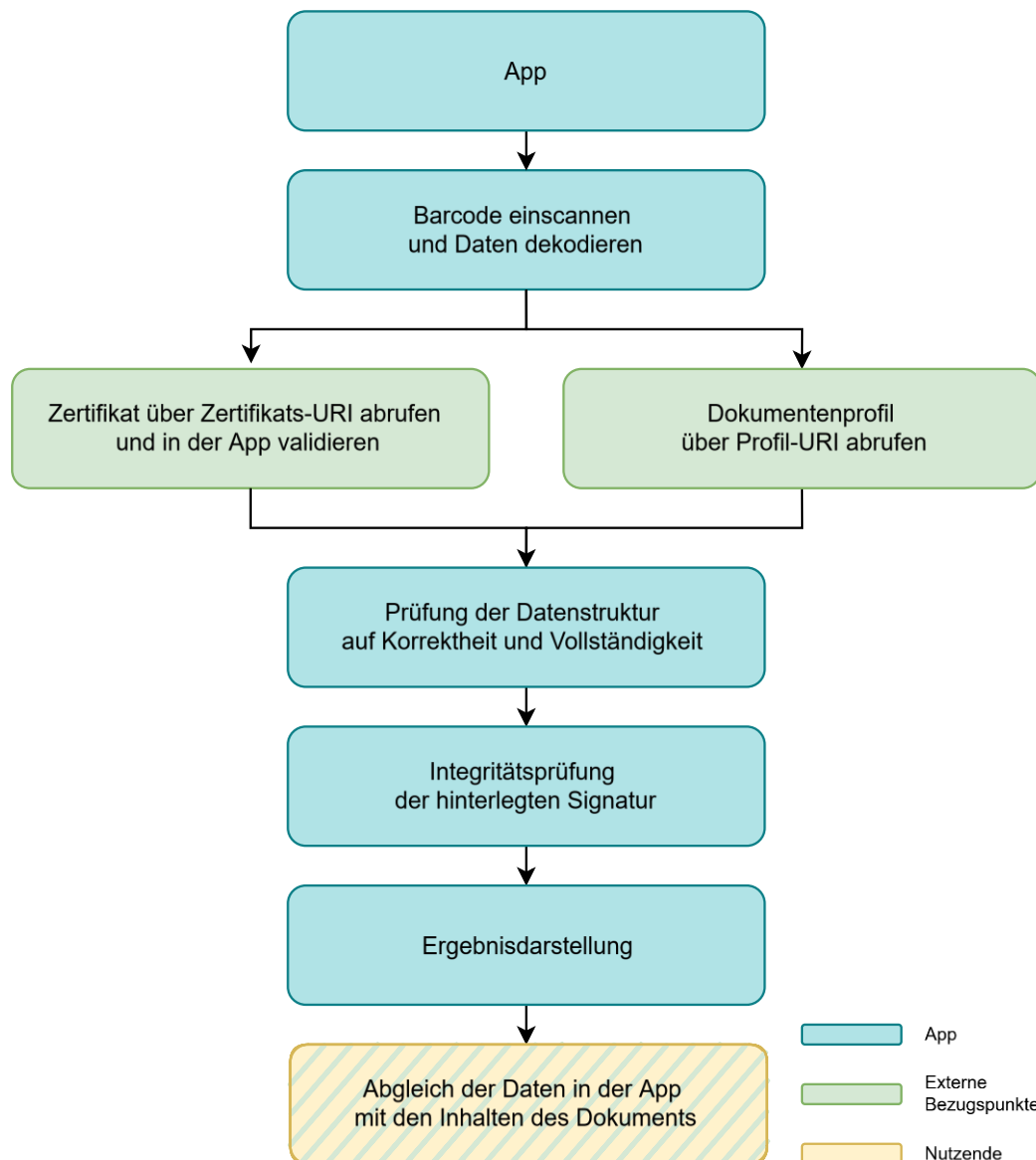


Abbildung 1: Validierung des optischen Siegels mittels einer App (ohne Rückrufmechanismus)

Der Validierungsprozess wird analog zu Abbildung 1 durchgeführt, in dem im ersten Schritt mittels der App das digitale Siegel eingescannt wird. Die enthaltenen Daten werden dekodiert und die verwendeten Profile und Zertifikate über die enthaltenen Bezugsbezugspunkte heruntergeladen. Die App muss überprüfen, ob die Zertifikatskette gültig ist. Mittels des Profils kann die Datenstruktur auf Korrektheit und Vollständigkeit geprüft und die Inhalte dem Nutzenden dargestellt werden. Die Validierung der elektronischen Signatur erfolgt im Anschluss und wird den Nutzenden ebenfalls dargestellt. (Sollte ein Rückrufmechanismus vorhanden sein, muss die Überprüfung – ob ein Rückruf für das Siegel vorhanden ist – ebenfalls in diesem Schritt erfolgen und in das Prüfergebnis einfließen.) Für die Validierung der Signatur sollte das Schalenmodell verwendet werden. Im letzten Schritt müssen die angezeigten Daten mit den Inhalten des zugrundeliegenden Dokuments durch die Nutzenden abgeglichen werden.

Die Nutzenden müssen die Möglichkeit haben, folgende Informationen in der App einzusehen:

- Zertifikatsinhaber: Den Nutzenden muss ersichtlich sein, wer das Dokument gesiegelt hat und damit Aussteller des Dokuments ist.
- Zertifikatsaussteller: Den Nutzenden muss dargestellt werden, wer das Zertifikat mit welchen Qualitätsmerkmalen (z.B. fortgeschritten, qualifiziert, usw.) ausgestellt hat.
- Vertrauensanker des Zertifikats: Den Nutzenden muss ersichtlich sein, ob das verwendete Zertifikat als vertrauenswürdig eingestuft werden kann. Grundsätzlich können nach dieser Richtlinie die EU-TL sowie die Verwaltungs-PKI als vertrauenswürdig eingestuft werden. Bei Verwendung weiterer Vertrauensanker ist dies den Nutzenden in der App sowie bei der Signaturprüfung transparent darzustellen.
- Signaturstatus: Den Nutzenden muss niederschwellig das Ergebnis des Validierungsprozesses (gültig, ungültig, unbestimmt) dargestellt werden.
- Zertifikatsdetails: Die technischen Details des verwendeten Zertifikats müssen den Nutzenden auf deren Verlangen dargestellt werden, analog zu dem verbreiteten Modell in beispielsweise Webbrowsern.
- Gültigkeitszeitraum: Wenn angegeben, muss der Gültigkeitszeitraum den Nutzenden angezeigt werden. Findet die Validierung außerhalb des Gültigkeitszeitraums statt, muss dies den Nutzenden der App ebenfalls angezeigt werden.

6 Rückrufmechanismus

Grundsätzlich sollte überlegt sein, ob ein Rückrufmechanismus fachlich unbedingt notwendig ist. An dieser Stelle wird der *Bitstring Status List*-Mechanismus (W3C, 2025) in Form eines Verifiable Credentials als Proof-of-Concept vorgestellt. Diese beruht auf dem Konzept, dass alle ausgestellten Nachweise (Siegel) einen binären Indexeintrag in einer Rückrufliste erhalten. So kann die Rückrufliste als Ganzes komprimiert und damit sehr kompakt veröffentlicht werden. Diese Vorgehensweise ist im hohen Maße datenschutzfreundlich. Dieser Mechanismus ist unter (W3C, 2025) im Detail spezifiziert. Nachfolgend wird der Mechanismus zusammengefasst erläutert und im Anschluss genauer spezifiziert:

Aussteller von Nachweisen können die Möglichkeit anbieten, Statusinformationen mit Hilfe einer Rückrufliste bzw. *Bitstring Status List* zu pflegen. Jeder Nachweis wird einem eindeutigen Index zugeordnet. Der Index wird aus Gründen des Datenschutzes zufällig und ohne Doppelbelegungen vergeben.

Erfolgt ein Rückruf eines Nachweises wird diesem unter dem dazugehörigen Index der Wert „1“ zugewiesen. Nicht zurückgerufene Nachweise sind mit dem Wert „0“ initialisiert. Der sich daraus ergebende Bitstring lässt sich in hohem Maße komprimieren, da davon auszugehen ist, dass ein Großteil der Nachweise nicht zurückgezogen wird. Dem liegt zugrunde, dass sich dadurch große Sektionen mit dem Wert „0“ ergeben, was die Komprimierbarkeit mittels des Kompressionsalgorithmus GZIP stark erhöht. Für die Rückrufliste wird eine Mindestlänge von 131.072 Bit empfohlen, um ein gewisses Level an Datenschutz zu gewährleisten. Bei wenigen Rückrufen würde die komprimierte Liste mit der angegebenen Mindestlänge eine Größe von wenigen Hundert Bytes aufweisen.

Die komprimierte Liste wird im Anschluss zusätzlich mit Base64URL kodiert. Der daraus resultierende String wird nun den Anfragenden als Teil eines „*BitstringStatusListCredential*“ zur Verfügung gestellt. Neben der kodierten Liste enthält die Datei weitere Daten, wie z.B. den Bezugspunkt der Rückrufliste, aber auch kryptographische Daten, um die Integrität der Liste zu überprüfen. Die Liste sollte auf die gleiche Weise kryptographisch abgesichert sein, wie die Nachweise selbst. Sollte die *Bitstring Status List* als Rückrufmechanismus verwendet werden, liegt die Zuständigkeit für die Betreuung bei den Herausgebenden der Nachweise. Pro Zertifikat ist eine eigene Rückrufliste zu führen. Für die Rückrufliste und die Nachweise wird dasselbe Zertifikat und derselbe Signaturalgorithmus verwendet.

Nachfolgend finden sich die Werte die für das „*BitstringStatusListCredential*“, welche für diese Technische Richtlinie festgelegt sind:

Tabelle 13: Festgelegte Werte für „BitstringStatusListCredential“

Inhalt	Wert
id	Entspricht „statusURI“, siehe Kapitel 3.2 Beispiel: „https://example.com/status“
type	"BitstringStatusListCredential"
validFrom	Entspricht dem Gültigkeitsbeginn (in UTC) des Zertifikats Beispiel: "2026-01-01T00:00:00Z"
validUntil	Entspricht dem Gültigkeitsende (in UTC) des Zertifikats Beispiel: "2029-01-01T00:00:00Z"
credentialSubject.type	"BitstringStatusList"
credentialSubject.statusPurpose	"revocation"

<i>Inhalt</i>	<i>Wert</i>
credentialSubject.encodedList	Multibase-kodierte Base64URL- Repräsentation (ohne Padding) (RFC4648) der GZIP-komprimierten (RFC1952) Bitstring-Werte Beispiel: "uH4sIAAAAAAAAAA-3BMQEAAADCoPVPbQwfoAAAAAAAAAAAAAAAAAAIC3AYbSVKsAQAAA"
proof.verificationMethod	Entspricht <i>Certificate Reference</i> , SHASUM des Zertifikats, siehe Kapitel 3.1 Beispiel: „7f043c5b99d7c8057efd672ecda8091115221925“

Das „BitstringStatusListCredential“ enthält verschiedene Elemente. Neben den festgelegten Werten aus Tabelle 13 sind weitere Inhalte wie „proof“ enthalten. Dort sind die nötigen Informationen gebündelt, um die Integrität der Rückrufliste kryptographisch prüfen zu können und können dem nachfolgenden Listing entnommen werden. Zum Übermitteln der Daten im Web können verschiedene Medientypen (MIME-Typen) verwendet werden. Im Rahmen dieser Technischen Richtlinie wird sich auf den Medientyp „application/vc“ festgelegt.

Ein „BitstringStatusListCredential“ mit dem Medientyp „application/vc“ hat den folgenden Aufbau mit beispielhaften Daten:

```
{
  "@context": [
    "https://www.w3.org/ns/credentials/v2"
  ],
  "id": "https://example.com/status",
  "type": [
    "VerifiableCredential",
    "BitstringStatusListCredential"
  ],
  "issuer": "https://example.com",
  "validFrom": "2026-05-18T00:00:00Z",
  "validUntil": "2029-01-01T00:00:00Z",
  "credentialSubject": {
    "id": "https://example.com/status#list",
    "type": "BitstringStatusList",
    "statusPurpose": "revocation",
    "encodedList": "uH4sIAAAAAAAAAA-
3BMQEAAADCoPVPbQwfoAAAAAAAAAAAAAAAAAIC3AYbSVKsAQAAA"
  },
  "proof": {
    "type": "DataIntegrityProof",
    "created": "2026-05-18T12:00:00Z",
    "verificationMethod": "7f043c5b99d7c8057efd672ecda8091115221925",
    "cryptosuite": "ecdsa-rdfc-2019",
    "proofPurpose": "assertionMethod",
    "proofValue":
"z3mKjX9wPqRtSfV4uY2BcN8mKqLxWpZsYtRnVbXdFgHjKmNpQrStVwXyZ1bCdsKfMnPrStVwX
yZ2bCdEfGhJkMnP4"
  }
}
```

Neben der Rückrufliste wird auch definiert, welche Informationen die zu überprüfenden Verifiable Credentials haben müssen um den Mechanismus zu realisieren. Dies wird unter der Bezeichnung „BitstringStatusListEntry“ genauer spezifiziert. Da im Kontext dieser Technischen Richtlinie das optisch verifizierbare Siegel das Verifiable Credential ist, kann der Teil nur bedingt umgesetzt werden. Dort wird in einem anderen Format und ausschließlich auf digitaler Basis gearbeitet. Die notwendigen Werte sind, wie in Kapitel 3.2 beschrieben, im Siegel kodiert. Um eine klare Zuordnung und eine einheitliche Grundlage zu ermöglichen, werden die weiteren relevanten Werte nachfolgend festgelegt beziehungsweise zugeordnet:

Tabelle 14: Festgelegte Werte für „BitstringStatusListEntry“

Inhalt	Wert
type	"BitstringStatusListEntry"
statusPurpose	"revocation"
statusListIndex	Entspricht „statusListIndex“, siehe Kapitel 3.2. Ein Integer-Wert ≥ 0 , der als String im Dezimalsystem (Basis 10) dargestellt wird. Beispiel: "424242"
statusListCredential	Entspricht „statusURI“, siehe Kapitel 3.2 Beispiel: „https://example.com/status“

Die unter Kapitel „3. Algorithms“ in (W3C, 2025) enthalten Vorgaben zum Generieren der Rückrufliste und den Vorgaben für den Prüfprozess innerhalb der App zum Überprüfen des Status, müssen dementsprechend implementiert werden.

Literaturverzeichnis

DOC9303-13. ICAO: Doc 9303 Machine Readable Travel Documents – Part 13: Visible Digital Seals, Eighth Edition, March 2021.

eIDAS-VO. *Verordnung (EU) Nr. 910/2014 des Europäischen Parlaments und des Rates vom 23. Juli 2014 über elektronische Identifizierung und Vertrauensdienste für elektronische Transaktionen im Binnenmarkt und zur Aufhebung der Richtlinie 1999/93/EG.*

ISO8601. *Date and time format, 2019.*

RFC1952. *GZIP file format specification version 4.3, May 1996.*

RFC3279. *Algorithms and Identifiers for the Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile, April 2002.*

RFC4122. *A Universally Unique Identifier (UUID) URN Namespace, July 2005.*

RFC4648. *The Base16, Base32, and Base64 Data Encodings, October 2006.*

RFC7519. *JSON Web Token (JWT), May 2015.*

TR-03137-1. *Technical Guideline TR-03137: Optically Verifiable Cryptographic Protection of non-electronic Documents (Digital Seal).*

W3C. 2025. *Bitstring Status List. [Online] 15. 05 2025. [Zitat vom: 20. 03 2026.] <https://www.w3.org/TR/vc-bitstring-status-list/>.*

X.680, ITU-T. *OSI networking and system aspects – Abstract Syntax Notation One (ASN.1): Specification of basic notation, 02/2021.*